

Oppty Chats

Full Stack Project Audit Report

Generated: April 04, 2026 17:50

1. Project Overview

Oppty Chats is a real-time internal messaging platform for Oppty TechHub. It supports direct messages, group chats, file sharing, and role-based access control.

Component	Technology	Deployment
Frontend	React 19 + Vite 8	Vercel
Backend	Django 5.2 + DRF + Channels	Render
Database	SQLite (dev) / PostgreSQL (prod)	Render Postgres
Real-time	Django Channels + Daphne (ASGI)	Render
Auth	Session-token Bearer	—
File Storage	Local media/ (dev)	Render ephemeral disk

2. Features Implemented

Feature	Description	Status
Authentication	Email/password login, OTP forgot-password, reset	✓ Complete
Direct Messages	1-to-1 DM with real-time WebSocket delivery	✓ Complete
Group Chats	Create groups, add/remove members, admins-only mode	✓ Complete
File Sharing	Photo, video, document upload; link sharing	✓ Complete
Profile Management	Avatar, name, phone, bio — all saved to DB	✓ Complete
Unread Badges	Per-chat unread count, mark-as-read on open	✓ Complete
Chat Ordering	Sorted by latest message timestamp	✓ Complete
Contact Info Panel	Slide-in panel with phone, email, bio, members	✓ Complete
Super Admin Hub	Employee & group management, message feed	✓ Complete
Role-Based Access	employee / admin / superadmin enforced on API	✓ Complete
In-Chat Search	Message search with highlight and navigation	✓ Complete
Emoji Picker	Quick emoji tray in composer	✓ Complete

Responsive UI	Mobile bottom nav, desktop sidebar	✓ Complete
---------------	------------------------------------	------------

3. Issues Found & Status

Severity	Issue	Root Cause	Resolution
HIGH	CORS blocked on production	FRONTEND_URL env var not set on Render	Fixed — env var set; auto-logout on 401/403
HIGH	Profile pic not saving	saveAuthUser() called before definition (hoisting bug)	Fixed — moved before useEffect
HIGH	Images in chat not rendering	Daphne doesn't serve media via Django static() helper	Fixed — custom MediaFileMiddleware in asgi.py
HIGH	Attachment URL wrong path	MessageBubble prepended /api to media URL → 404	Fixed — resolveUrl() strips /api, handles absolute URLs
MEDIUM	Page refresh 404 on Vercel	SPA routes not handled by Vercel	Fixed — vercel.json rewrite rule
MEDIUM	Login 401 on production	create_superuser not run on deploy	Fixed — added to nixpacks.toml build commands
MEDIUM	Stale session after redeploy	SECRET_KEY defaulting to insecure value	Partial — code fixed; env var must be set on Render
MEDIUM	messages/upload returning 404	Route shadowed by messages/	Fixed — specific routes moved before catch-all
MEDIUM	Chat list not sorted	No sort applied to filtered chats	Fixed — sorted by last message createdAt desc
MEDIUM	Sender avatar broken	senderAvatar missing from normalizeBackendMessage	Fixed — field added; onError fallback to initials
LOW	Hardcoded 99+ badge	Static badge, not real unread count	Fixed — real count with localStorage persistence
LOW	Profile fields not persisted	Only avatar saved; name/phone/bio ignored	Fixed — PATCH /api/auth/profile handles all fields
LOW	Default pic for all users	profiledp.jpeg used regardless of DB avatar	Fixed — initials fallback; real photo from DB
LOW	WS messages missing senderAvatar	normalizeBackendMessage lacked senderAvatar	Fixed — field added to normalization
INFO	No Redis in production	InMemoryChannelLayer — WS won't broadcast across workers	Pending — add Redis on Render
INFO	Media on ephemeral disk	Files lost on Render redeploy	Pending — migrate to S3/Cloudinary
INFO	OTP not emailed	OTP returned in API response only	Pending — integrate SMTP/SendGrid
INFO	No password validators	AUTH_PASSWORD_VALIDATORS is empty	Pending — add validators in settings.py
INFO	Unused axios dependency	axios in package.json but fetch() used everywhere	Minor — remove axios

4. API Endpoints

Method	Endpoint	Description	Access
POST	/api/auth/login	Login	Public
GET	/api/auth/profile	Get current user profile	Auth
PATCH	/api/auth/profile	Update name/phone/bio/avatar	Auth
POST	/api/auth/forgot-password	Request OTP	Public
POST	/api/auth/verify-otp	Verify OTP	Public
POST	/api/auth/reset-password	Reset password	Public
GET	/api/auth/employees	List employees	Auth
POST	/api/auth/employees	Create employee	SuperAdmin
PATCH	/api/auth/employees/:id/permissions	Update permissions	SuperAdmin
GET	/api/auth/all-messages	All messages (admin)	SuperAdmin
GET	/api/groups	List groups	Auth
POST	/api/groups	Create group	SuperAdmin
PUT	/api/groups/:id	Update group	SuperAdmin
DELETE	/api/groups/:id	Delete group	SuperAdmin
PATCH	/api/groups/:id/admins-only	Toggle admins-only	SuperAdmin
PUT	/api/groups/:id/members/:empId	Add member	SuperAdmin
DELETE	/api/groups/:id/members/:empId	Remove member	SuperAdmin
GET	/api/messages/:chatId	Get messages	Public
POST	/api/messages	Send text message	Public
POST	/api/messages/upload	Upload file	Auth
POST	/api/messages/link	Send link	Auth
GET	/health	Health check	Public
WS	/ws/chat/:chatId?token=...	Real-time WebSocket	Token

5. Database Schema

Employee

Field	Type	Notes
id	AutoField (PK)	
email	EmailField (unique)	Login identifier
password	CharField(128)	bcrypt hashed
name	CharField(255)	
role	CharField(20)	employee / admin / superadmin

can_create_groups	BooleanField	Default False
group	FK → ChatGroup	Nullable
avatar	ImageField	media/avatars/
phone	CharField(30)	Optional
bio	TextField	Optional
otp_value	CharField(6)	Temporary OTP
otp_expires_at	DateTimeField	Nullable
created_at	DateTimeField	auto_now_add

ChatGroup

Field	Type	Notes
id	AutoField (PK)	
name	CharField(255, unique)	
description	TextField	Optional
members	M2M → Employee	
created_by	FK → Employee	CASCADE
admins_only	BooleanField	Default False
created_at	DateTimeField	auto_now_add

Message

Field	Type	Notes
id	AutoField (PK)	
chat_id	CharField(255, indexed)	dm_X_Y or group id
sender	FK → Employee	CASCADE
receiver	FK → Employee	Nullable, SET_NULL
text	TextField	Empty for file-only messages
attachment_type	CharField(20)	photo/video/document/link
attachment_url	CharField(500)	Absolute URL stored
attachment_file_name	CharField(255)	
attachment_file_size	PositiveIntegerField	Nullable
attachment_mime_type	CharField(150)	
created_at	DateTimeField	auto_now_add, indexed

6. Security Review

Status	Finding
✓ PASS	Passwords hashed with Django bcrypt (make_password)

✓ PASS	Session tokens validated against DB expiry on every request
✓ PASS	CORS restricted to FRONTEND_URL env var in production
✓ PASS	Role-based permissions enforced on all sensitive endpoints
✓ PASS	CSRF trusted origins configured for production domains
✓ PASS	SESSION_COOKIE_SECURE=True in production
✓ PASS	SESSION_COOKIE_HTTPONLY=True always
■ WARN	SECRET_KEY defaults to insecure value if env var not set
■ WARN	AUTH_PASSWORD_VALIDATORS is empty — no password strength rules
■ WARN	Media files served without authentication — any URL is public
■ WARN	OTP not sent via email — in API response only (dev)
✗ RISK	No rate limiting on login or OTP endpoints
✗ RISK	File upload has no virus scanning or content validation
✗ RISK	WebSocket accepts unauthenticated connections (employee=None)

7. Pending / Recommended Tasks

Priority	Task	Reason
P1 - Critical	Set SECRET_KEY as stable env var on Render	Prevents session invalidation on redeploy
P1 - Critical	Add Redis on Render + set REDIS_URL	Required for WebSocket broadcast across workers
P1 - Critical	Reject unauthenticated WebSocket connections	Close if employee is None in connect()
P2 - High	Migrate file storage to S3 or Cloudinary	Render ephemeral disk loses files on redeploy
P2 - High	Add rate limiting to login/OTP endpoints	Prevent brute force attacks
P2 - High	Integrate SMTP for OTP email delivery	Currently OTP is only in API response
P3 - Medium	Add AUTH_PASSWORD_VALIDATORS in settings.py	Enforcing minimum password strength
P3 - Medium	Add file type/size validation on upload	Prevent malicious file uploads
P3 - Medium	Remove unused axios dependency	Reduces bundle size
P4 - Low	Add pagination to message list endpoint	Performance with large chat histories
P4 - Low	Add message read receipts (double tick)	Better delivery status UX
P4 - Low	Add typing indicators via WebSocket	Real-time typing status

8. Summary

Category	Count
Total Issues Found	19

HIGH Severity (all Fixed)	4
MEDIUM Severity (all Fixed)	6
LOW Severity (all Fixed)	4
INFO / Pending	5
Security Warnings	4
Security Risks	3
Frontend Diagnostic Errors	0
API Endpoints	23
DB Tables	3
Migrations Applied	7

Overall the project is in good shape for a development/staging environment. Core features are complete and functional. Before going to production, the P1 critical items (SECRET_KEY, Redis, WebSocket auth) must be addressed.